

# 코드 작성 및 보안 정책 가이드라인

생성일: 2025-10-20 17:20

## 1. 목적

본 문서는 회사 내 모든 개발자가 안전하고 일관성 있는 코드를 작성할 수 있도록 보안 및 코드 작성 정책을 명확히 규정하기 위함입니다.

민감정보 유출 방지 및 보안 사고 예방을 목표로 합니다.

## 2. 민감정보 취급 기준

- 주민등록번호, 전화번호, 이메일 등 개인정보는 절대 소스코드에 직접 포함 금지
- API 키, 비밀번호, 인증 토큰 등은 하드코딩 금지하며, 환경변수 또는 안전한 비밀관리 시스템 사용
- 민감정보를 저장하거나 전송 시 반드시 암호화 적용

## 3. 코드 작성 시 보안 수칙

- 입력값 검증 (Input Validation) 철저히 수행
- SQL 인젝션, XSS, CSRF 등 웹 취약점 방어 코딩 적용
- 비밀번호 등 민감정보는 단방향 해시(예: bcrypt) 처리
- 로그에 민감정보 출력 금지
- 외부 라이브러리 사용 시 보안 패치 주기적 적용

## 4. 코드 리뷰 및 감사

- 모든 코드는 병합 전 반드시 2명 이상의 리뷰 진행
- 보안 관련 코드 변경 시 별도 보안 리뷰 필수
- 정기적 보안 감사 실시 (자동화 도구 및 AI 기반 감사 포함)

## 5. 보안 사고 대응

- 민감정보 유출 의심 시 즉시 보안팀에 보고
- 사고 발생 시 원인 분석 및 재발 방지 대책 수립
- 보안 사고 기록 및 감사 로그 철저히 보관

## 6. AI 보안 감사 시스템 활용

- 개발자는 AI 보안 감사 도구를 사용하여 민감정보 포함 여부를 사전에 점검
- 경고 및 수정 제안을 적극 반영하여 안전한 코드 작성
- AI 시스템에서 감지된 사항은 반드시 확인 후 조치

## 7. 교육 및 인식 제고

- 보안 정책 및 최신 보안 위협에 대한 정기 교육 참여 의무
- 보안 인식 강화 캠페인 및 툴 사용법 안내 지속적 시행

## 부록

- 민감정보 정규표현식 예시
- 주요 보안 취약점 및 방어 방법
- AI 보안 감사 도구 사용법 가이드